

Эскалация привилегий. Shatter attack.

Доклад

Выполнила: студентка группы НКАбд-04-24
Подхалюзина Виолетта Михайловна
Преподаватель: д.ф.-м.н., проф. Кулябов Д. С.

Российский университет дружбы народов им. П. Лумумбы

15 мая 2026 г.

Содержание I

1. Информация
2. Вводная часть
3. Основная часть
4. Заключение

Раздел 1

1. Информация

Докладчик

Подхалюзина Виолетта
Михайловна
студентка группы
НКАбд-04-24
РУДН им. П. Лумумбы
Студбилет: 1132246761



Раздел 2

2. Вводная часть

ОС как фундамент: Уязвимости ОС сводят на нет внешние периметры безопасности [1].

Эскалация привилегий: Критически важная фаза любой АРТ-атаки.

Shatter attack: Уязвимость из-за отсутствия мандатного контроля в графической подсистеме.

Значимость: Понимание векторов атак на ИРС необходимо для построения надежных систем.

Цели и задачи работы

Цель: Изучить архитектурную уязвимость оконной подсистемы ОС Windows и механизмы защиты.

Задачи:

Рассмотреть эскалацию привилегий и изоляцию процессов. Проанализировать архитектуру Win32 API. Разобрать алгоритм классической Shatter-атаки. Изучить механизмы защиты (Session 0 Isolation, MIC/UIPI).

Раздел 3

3. Основная часть

Эскалация привилегий — несанкционированное повышение прав доступа субъектом [2].

Основные виды:

Вертикальная: Получение прав админа или ядра (SYSTEM) обычным юзером.

Горизонтальная: Получение прав другого юзера того же уровня (например, кража сессий).

Изоляция и кольца защиты

Основа защиты ОС — аппаратные кольца (Protection Rings) [3].

Ring 0 (Ядро): Полный доступ к железу (службы и драйверы).

Ring 3 (User-mode): Изолированные приложения. Переход между ними идет строго через системные вызовы (см. рис. 1).

Схема: аппаратные кольца

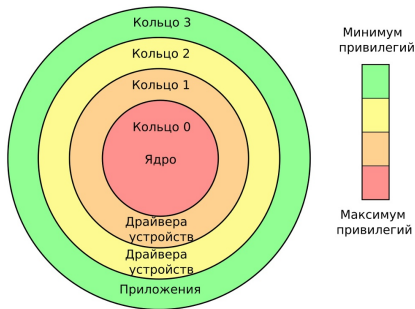


Рис. 1: Архитектура колец защиты

Графический интерфейс управляется событиями [4].

Общение окон идет через вызовы `SendMessage` и `PostMessage`.

Фундаментальная проблема: Старые ОС не проверяли уровень привилегий отправителя к получателю на одном рабочем столе.

Механизм Shatter-атаки

Атака позволяет выполнить произвольный код с правами SYSTEM.

Этапы реализации:

Разведка: Поиск окна системной службы.

Внедрение: Загрузка шелл-кода в процесс-жертву (через WM_SETTEXT).

Триггер: Отправка сообщения с адресом шелл-кода (например, WM_TIMER).

Выполнение: Привилегированный процесс передает управление коду.

Схема: реализация Shatter-атаки

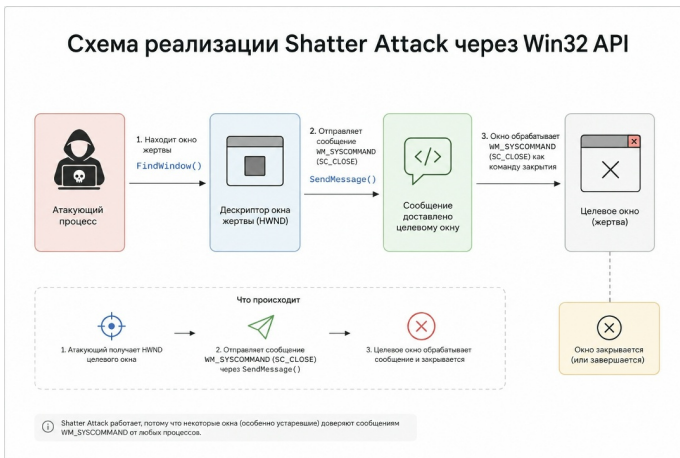


Рис. 2: Схема передачи сообщений и перехвата потока

Session 0 Isolation (с Windows Vista)

Проблема: Службы и первый юзер сидели в общем Сеансе 0.

Решение: Сеанс 0 жестко изолирован *только* для системных служб.

Итог: Пользовательские процессы физически не видят окна системных служб (см. рис. 3).

Схема: разделение сеансов



Рис. 3: Механизм Session 0 Isolation

User Interface Privilege Isolation (UIPI)

(Надстройка над механизмом MIC [5])

Уровни целостности: Low, Medium, High, System.

Правило: Процесс с низким уровнем не может слать сообщения окну с высоким.

Итог: Блокировка Shatter-атак внутри одного сеанса (см. рис. 4).

Схема: механизм UIPI



Рис. 4: Механизм UIPI и фильтрация сообщений

Раздел 4

4. Заключение

Недочеты в механизмах IPC могут привести к полной компрометации ядра (Ring 0). Классическая Shatter-атака доказала слабость дискреционного подхода (DAC). Современная защита опирается на строгий мандатный контроль (MAC) [6]. Надежная безопасность требует комплексной изоляции на всех уровнях.

Спасибо за внимание!

Готова ответить на ваши вопросы.

Список литературы

1. ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. М.: Стандартинформ, 2007.
2. Сухомлин В. А. Введение в анализ информационной безопасности. Теоретико-методологические основы. М.: Горячая линия - Телеком, 2021. 284 с.
3. Кулябов Д. С., Королькова А. В. Архитектура и принципы построения операционных систем: Учебное пособие. М.: РУДН, 2018. 156 с.
4. Русинович М., Соломон Д., Ионеску А. Внутреннее устройство Windows (Windows Internals), 7-е издание. Часть 1. СПб.: Питер, 2018. 800 с.
5. Малюк А. А. Информационная безопасность: концептуальные и методологические основы защиты информации. Учебное пособие. М.: Горячая линия-Телеком, 2020. 280 с.